HALX: Privacy-Preserving Hybrid Attention-LSTM and XGBoost Framework for Proactive Threat Detection in Financial Networks

Mubasshir Ahmed
Victoria University
Melbourne, Australia
mubasshir.ahmed@live.vu.edu.au

Md Mazharul Islam
Electrical and Computer Engineering
North South University
Dhaka, Bangladesh
mazharul.islam1@northsouth.edu

***Abstract*—TBD.**

***Index Terms*—Intrusion detection, financial cybersecurity, attention-LSTM, XGBoost, k-anonymity, differential privacy, explainable AI, PCI DSS, GDPR**

I. Introduction

Financial institutions operate some of the most attractive targets on the Internet: payment switches, core-banking platforms, trading gateways and the cloud services that now host them. The financial sector had the second-highest average breach cost of 17 industries in the IBM 2024 study, at US$6.08 million per incident [1]. Banks are exposed to DDoS, ransomware, insider misuse and multi-stage intrusions that blend into legitimate traffic [2], [3]. Signature-based intrusion detection systems (IDS) miss previously unseen attacks, and a mostly reactive security operations centre (SOC) learns of an intrusion only after the damage is done. This motivates *proactive* detection: every flow is scored as it is observed, and analysts are given a ranked and explained set of alerts rather than a raw stream of events.

Machine learning (ML) based network IDS are the usual answer, and recent work has proposed increasingly elaborate deep models: CNN–LSTM hybrids [4], [5], attention-augmented recurrent networks [6] and transformers [7]–[9]. Deploying such models inside a regulated financial institution, however, raises three practical issues that benchmark accuracy does not capture. *(i) Tabular reality.* Flow records are tabular, and on tabular data gradient-boosted trees remain hard to beat [10]. A deep detector that is not compared against a tuned boosted-tree baseline may overstate its benefit. *(ii) Privacy and compliance.* Flow features such as transferred volumes, session durations and TTL or window values act as *quasi-identifiers* of customers and hosts. Under the GDPR's data-protection-by-design principle (Art. 25) [11] and the PCI DSS requirement to protect account data [12], the detector, its feature store and the statistics shipped with it must not become a new leakage channel. *(iii) Auditability.* Compliance officers and SOC analysts need to know *why* a flow was flagged and how urgent it is [13].

This paper presents **HALX** (Hybrid Attention-LSTM + XGBoost), a detection pipeline for financial network infrastructure that addresses all three issues. Our contributions are:

- A hybrid detector in which a feature-token Attention-LSTM encoder learns a representation of each flow, and an XGBoost head [14] scores the representation together with the privatized raw features. Its output is a calibrated threat probability, mapped to three severity tiers.
- A privacy-preserving inference layer with *formally stated* guarantees. Multidimensional k-anonymity (Mondrian [15]) is enforced on quasi-identifiers, and the preprocessing statistics are released under (ε, δ)-differential privacy with zCDP accounting [16].
- A reproducible evaluation on UNSW-NB15 (official train/test split) [17] and CICIDS2017 [18] against seven baselines over three seeds, with an ablation study, a privacy–utility analysis, attention-based explanations and CPU latency measurements. All code and generated results are released.[1]

II. Related Work

Deep and hybrid IDS. CNN–LSTM models combine convolutional feature extraction with recurrent modelling and are a common baseline on CICIDS2017 and UNSW-NB15 [4], [5]. Alashjaee [6] adds self-attention to a CNN–LSTM and shows in an ablation that the attention layer helps. Transformer-based detectors treat flow features as tokens [7], [9], [19]. FlowTransformer showed that the choice of input encoding and classification head matters more than the transformer variant [8], and BERT-style language models have also been adapted to traffic [20]. Closest to our work, Sajid et al. [21] use XGBoost and a CNN as feature selectors in front of an LSTM classifier. HALX reverses that order: the deep encoder produces the representation and the boosted trees make the decision. This follows evidence that trees are the stronger final learner on tabular data [10], [22].

ML security in finance. Surveys of digital banking identify DDoS, ransomware, insider threats and phishing as the

[1] https://github.com/mazharulmd/Threat-Detection-for-Financial-Systems

dominant threat classes [2]. Islam et al. [3] detect DDoS on a banking IoT monitoring system. Recent studies report SOC deployments in core-banking systems [23] and proactive detection in emulated bank networks [24]. They stress regulatory constraints, but none of them states a formal privacy guarantee for the detector itself.

Privacy-preserving IDS. Most privacy work on IDS concerns *training*: federated learning [25] with differentially private updates [26]–[28], or DP-SGD [29]. We address a complementary problem that is often overlooked: what the deployed detector *exposes*, namely generalized quasi-identifiers in its inputs and logs and the normalization statistics shipped with the model. The two approaches can be combined.

Evaluation pitfalls. CICIDS2017 contains labelling and flow-construction errors [30], and models trained on it transfer poorly to related traffic [31]. Arp et al. [32] catalogue pitfalls such as data snooping and inappropriate baselines. We follow their recommendations: the test partitions are never used for model selection, a tuned XGBoost baseline is always included, and every number is reported as a mean over seeds. Explainability is surveyed in [13], and [33] pairs XGBoost with SHAP for NIDS. HALX instead explains each alert through its intrinsic attention weights.

III. Threat Model and Problem Statement

We consider the network segment of a financial institution (for example core banking, payment switching or online banking front-ends) monitored by a flow exporter. Each bidirectional flow is summarized as a record $\mathbf{r} = (\mathbf{r}^{\mathrm{num}}, \mathbf{r}^{\mathrm{cat}})$ with d numeric and c categorical attributes. The adversary is an external or insider attacker whose activity (reconnaissance, exploitation, DoS/DDoS, brute force, botnet C&C, web attacks, backdoors) produces flows. The task is to output, for every flow, a threat score $p \in [0,1]$, a binary decision $\hat{y} = \mathbb{1}[p \geq \tau]$, an attack family and a severity tier. A second, *honest-but-curious* party is also considered: an operator, vendor or auditor who sees the detector's stored inputs and its released preprocessing statistics. Against this party HALX must limit re-identification of individual flows.

IV. Proposed Framework: HALX

Fig. 1 shows the three stages: (1) a privacy-preserving layer, (2) an Attention-LSTM encoder and (3) an XGBoost scoring head with severity triage. Algorithm 1 summarizes training.

A. Privacy-Preserving Layer

Suppression. Direct identifiers (IP addresses, ports, timestamps, flow IDs) are dropped before any processing.

Quasi-identifier generalization. Let $Q \subset \{1, \ldots, d\}$ be the quasi-identifiers (QIs). On UNSW-NB15 these are duration, source and destination bytes, and source TTL; on CICIDS2017 they are flow duration, forward and backward payload lengths, and the initial forward TCP window. Volumes play the role of transaction sizes, and TTL or window values fingerprint operating systems. After a public, data-independent transform $g(x) = \mathrm{sign}(x)\log(1+|x|)$, we build a strict Mondrian partition [15] of the training QIs. Each region is split recursively at the median of its widest normalized QI, as long as both children keep at least k records. Every record, in training or at inference, is routed to its leaf and its QIs are replaced by the leaf median. Hence every generalized QI vector the detector stores or logs is shared by at least k training records (k-anonymity [34]). We use $k = 10$ by default and verify the smallest equivalence class after fitting.

DP standardization. Standardization needs per-feature means and variances, which are normally shipped with a model and can reveal individual records when an outlier dominates. We release them with the Gaussian mechanism. With values clipped to $[-C, C]$ ($C = 25$ in g-space) and public n, the sums $S_1 = \sum_i x_i$ and $S_2 = \sum_i x_i^2$ have replace-one sensitivities $2C$ and C^2. Each of the $2d$ released sums receives noise $\mathcal{N}(0, \Delta^2/2\rho_q)$ with $\rho_q = \rho/2d$, where

$$\rho = \left(\sqrt{\ln(1/\delta) + \varepsilon} - \sqrt{\ln(1/\delta)}\right)^2 \tag{1}$$

is the largest ρ for which ρ-zCDP implies (ε, δ)-DP, using $\varepsilon = \rho + 2\sqrt{\rho \ln(1/\delta)}$ [16]. By composition, the released statistics satisfy (ε, δ)-DP. We use $\varepsilon = 1$ and $\delta = 10^{-5}$. *Scope:* this protects the shipped statistics only. The network weights are not differentially private; that would require DP-SGD [29] (Sec. VII).

B. Attention-LSTM Encoder

UNSW-NB15's partition files carry no timestamps and are sorted by label, and the CICIDS2017 subset is randomly sampled. Sliding windows of *consecutive flows* would therefore leak labels through ordering, a form of data snooping [32]. HALX instead reads each flow record as a sequence of $T = d + c$ *feature tokens*, in the spirit of tabular transformers [22]:

$$\mathbf{t}_j = \tilde{x}_j\, \mathbf{w}_j + \mathbf{b}_j \;\; (j \leq d), \qquad \mathbf{t}_{d+i} = \mathbf{E}_i[r_i^{\mathrm{cat}}] + \mathbf{b}_{d+i}, \tag{2}$$

with $\mathbf{w}_j, \mathbf{b}_j \in \mathbb{R}^{16}$. A two-layer bidirectional LSTM [35] with 32 units per direction produces $\mathbf{H} = [\mathbf{h}_1, \ldots, \mathbf{h}_T] \in \mathbb{R}^{T \times 64}$. Here the recurrence models interactions between related features, for example packet counts, sizes and rates of the same direction. Multi-head self-attention [36] with $H = 4$ heads lets every token attend to every other:

$$\mathbf{Z} = \mathrm{LN}\big(\mathbf{H} + \mathrm{MHA}(\mathbf{H}\mathbf{W}^Q, \mathbf{H}\mathbf{W}^K, \mathbf{H}\mathbf{W}^V)\big), \tag{3}$$

where each head computes $\mathrm{softmax}(QK^\top/\sqrt{d_k})V$. Additive attention pooling then yields the flow embedding together with an importance distribution over features:

$$\alpha_j = \mathrm{softmax}_j\big(\mathbf{u}^\top \tanh(\mathbf{W}_a \mathbf{z}_j)\big), \qquad \mathbf{e} = \textstyle\sum_j \alpha_j \mathbf{z}_j. \tag{4}$$

The weights α_j are reported with each alert as an explanation. The encoder is trained end to end with a linear softmax head on the multi-class labels (cross-entropy, AdamW, learning rate $3 \cdot 10^{-3}$, cosine schedule, batch 1024). Early stopping uses validation macro-F1.

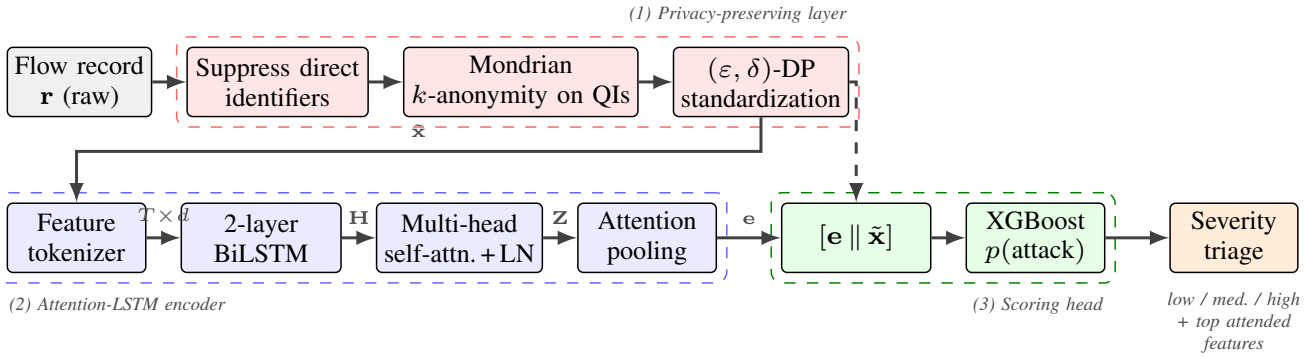


Fig. 1. The HALX pipeline. Raw flow records pass through the privacy layer (direct-identifier suppression, Mondrian k-anonymous generalization of quasi-identifiers, DP standardization). The Attention-LSTM encoder reads the privatized record as a sequence of feature tokens and produces an embedding $\mathbf{e}$. XGBoost scores $[\mathbf{e}\|\tilde{\mathbf{x}}]$, and the score is mapped to a severity tier together with the most-attended features.

Algorithm 1 HALX training

Require: training/validation flows $\mathcal{D}_{tr}, \mathcal{D}_{va}$; QI set Q; k, ε, δ

1: Drop direct identifiers; apply $g(\cdot)$; impute with training medians
2: Fit Mondrian tree on $\mathcal{D}_{tr}[Q]$ with leaf size $\geq k$; generalize Q
3: Release (μ, σ) via Gaussian mechanism with $\rho(\varepsilon, \delta)$ (Eq. 1); standardize $\rightarrow \tilde{\mathbf{x}}$
4: Oversample minority families in $\mathcal{D}_{tr}$ with SMOTE-NC [37]
5: Train encoder (Eqs. 2–4) with early stopping on $\mathcal{D}_{va}$
6: Extract $\mathbf{f} = [\mathbf{e}\|\tilde{\mathbf{x}}]$ for $\mathcal{D}_{tr}, \mathcal{D}_{va}$
7: Fit binary and multi-class XGBoost on $\mathcal{D}_{tr}$, early-stopped on $\mathcal{D}_{va}$
8: **return** privacy layer, encoder, XGBoost heads, threshold τ

C. XGBoost Scoring Head and Severity Triage

The deep encoder captures cross-feature structure, but on tabular data boosted trees model sharp, axis-aligned decision boundaries better [10]. The head therefore receives the concatenation $\mathbf{f} = [\mathbf{e} \,\|\, \tilde{\mathbf{x}}]$ of the embedding and the privatized features. One XGBoost model [14] estimates $p = P(\text{attack} \mid \mathbf{f})$ and a second predicts the attack family (up to 800 trees, depth 8, learning rate 0.08, early stopping on the validation split). Alerts with $p \geq \tau = 0.5$ are triaged into *low* ($p < 0.8$), *medium* ($0.8 \leq p < 0.95$) and *high* ($p \geq 0.95$) severity, so SOC analysts can work through high-severity alerts first.

V. Implementation and Experimental Setup

A. Datasets and Protocol

Table I summarizes the data. **UNSW-NB15** [17]: we use the official partition (175,341 training / 82,332 test flows; 9 attack families). Of the training part, 15% is held out for validation (stratified), and the official test set is used only for final reporting. Its attack mix differs from the training mix (55.1% vs. 68.1% attacks), which makes this the harder, more realistic setting. **CICIDS2017** [18]: we use the publicly released stratified subset of Yang et al. [38] (56,661 flows, 77 features, 6 grouped attack classes: DoS, PortScan, brute force, web attack, bot and infiltration). We split it 70/15/15 with stratification. The full 2.8M-flow release was not used for compute reasons. Because of known labelling issues in CICIDS2017 [30], we treat these results as a second, easier benchmark. Duplicate and constant columns (decided on training data only) are removed, infinite values are imputed with training medians, and categorical attributes keep their 31 most frequent levels plus an "other" bucket. SMOTE-NC [37] raises every attack family to at least 2% of the *training* split only. Every configuration is run with three seeds (0, 1, 2); the seed changes the train/validation split, SMOTE, weight initialization and the DP noise. We report mean ± std.

TABLE I
Dataset statistics after preprocessing

Dataset	Train	Val	Test	Tokens	Classes	Attack %
CICIDS2017 (subset)	39,662	8,499	8,500	60	7	59.9
UNSW-NB15 (official)	149,039	26,302	82,332	42	10	68.1 / 55.1†

†train / test; tokens = numeric features + categorical attributes.

B. Baselines

All baselines receive the same privatized inputs: (i) Isolation Forest [39], trained on benign flows only, with the threshold chosen on validation F1; (ii) Random Forest [40] (300 trees); (iii) XGBoost [14], configured exactly like the HALX head; (iv) a two-layer MLP (256 units); (v) CNN-LSTM in the style of [4] (two Conv1d layers followed by an LSTM over feature tokens); (vi) the HALX BiLSTM without attention and without the XGBoost head; and (vii) a feature-token Transformer (FT-Transformer style [22], two layers, 4 heads, $d = 64$), which stands in for the transformer IDS family [7], [8]. The deep baselines use the same optimizer, schedule and early-stopping rule as HALX.

C. Implementation

HALX is implemented in PyTorch 2.x, XGBoost 3.x and scikit-learn. The privacy layer (Mondrian tree and zCDP standardizer) is written from scratch in NumPy ($\approx$150 lines). All experiments ran on a 4-core x86 CPU with 16 GB RAM and no GPU, which matches the commodity servers found in a bank's SOC. Training runs for at most 15 epochs (8 on the larger UNSW-NB15) with patience 3. Metrics are accuracy, precision, recall, F1 and false-positive rate (FPR) for the binary attack-vs-benign decision at $\tau = 0.5$, ROC-AUC, and macro-F1 (M-F1) over attack families.

VI. Results

VII. Discussion and Limitations

What the privacy layer does and does not guarantee. HALX guarantees (a) k-anonymity of the quasi-identifiers that the detector stores, logs or forwards to analysts, and (b) (ε, δ)-DP of the released normalization statistics. It does *not* make the trained encoder or the trees differentially private: a white-box adversary could still mount membership inference against the weights. Training with DP-SGD [29] or in a federated setting across institutions [25], [26] is the natural next step. Mondrian generalization also does not protect against attribute disclosure within an equivalence class, a known limitation of k-anonymity [34].

Benchmarks vs. bank traffic. Neither benchmark is financial traffic, and models trained on CICIDS2017 are known to transfer poorly to other networks [31]. Our CICIDS2017 numbers come from a 2% stratified subset and are near the ceiling for every tree-based model. The UNSW-NB15 official split, where the test distribution differs from training, is more informative. Validating HALX on institution-specific flow logs under a data-sharing agreement is planned.

Temporal context. HALX scores flows independently. Multi-stage APT campaigns need cross-flow context (for example host-level session graphs or windows over timestamped flows); the public partitions used here lack timestamps, so we chose leak-free per-flow modelling over window-based designs whose gains could come from label ordering.

Adversarial robustness. We did not evaluate evasion attacks, which [32] lists among the evaluation gaps in ML-based security. We also did not test whether an attacker could manipulate the attention-based explanations; both are left to future work.

VIII. Conclusion

TBD.

References

[1] IBM Security, "Cost of a data breach report 2024," IBM Corp. and Ponemon Institute, Armonk, NY, USA, Tech. Rep., 2024. [Online]. Available: https://www.ibm.com/reports/data-breach

[2] M. Asmar *et al.*, "Integrating machine learning for sustaining cybersecurity in digital banks," *Heliyon*, 2024.

[3] U. Islam *et al.*, "Detection of distributed denial of service (DDoS) attacks in IOT based monitoring system of banking sector using machine learning models," *Sustainability*, 2022.

[4] A. Halbouni, T. S. Gunawan, M. H. Habaebi, M. Halbouni, M. Kartiwi, and R. Ahmad, "CNN-LSTM: Hybrid deep neural network for network intrusion detection system," *IEEE Access*, vol. 10, 2022.

[5] H. C. Altunay *et al.*, "A hybrid CNN+LSTM-based intrusion detection system for industrial IoT networks," *Engineering Science and Technology, an International Journal*, 2023.

[6] A. M. Alashjaee, "Deep learning for network security: an Attention-CNN-LSTM model for accurate intrusion detection," *Scientific Reports*, 2025.

[7] Z. Wu, H. Zhang, P. Wang, and Z. Sun, "RTIDS: A robust transformer-based approach for intrusion detection system," *IEEE Access*, vol. 10, pp. 64 375–64 387, 2022.

[8] L. D. Manocchio *et al.*, "FlowTransformer: A transformer framework for flow-based network intrusion detection systems," *Expert Systems with Applications*, vol. 241, p. 122564, 2024.

[9] U. C. Akuthota *et al.*, "Transformer-based intrusion detection for IoT networks," *IEEE Internet of Things Journal*, 2025.

[10] L. Grinsztajn, E. Oyallon, and G. Varoquaux, "Why do tree-based models still outperform deep learning on typical tabular data?" in *Advances in Neural Information Processing Systems (NeurIPS), Datasets and Benchmarks Track*, 2022.

[11] European Parliament and Council, "Regulation (EU) 2016/679 (General Data Protection Regulation)," Official Journal of the European Union, L 119, 2016.

[12] PCI Security Standards Council, "Payment card industry data security standard, v4.0," 2022.

[13] S. Neupane *et al.*, "Explainable intrusion detection systems (X-IDS): A survey of current methods, challenges, and opportunities," *IEEE Access*, 2022.

[14] T. Chen and C. Guestrin, "XGBoost: A scalable tree boosting system," in *Proc. 22nd ACM SIGKDD Int. Conf. Knowledge Discovery and Data Mining*, 2016, pp. 785–794.

[15] K. LeFevre, D. J. DeWitt, and R. Ramakrishnan, "Mondrian multidimensional k-anonymity," in *Proc. 22nd Int. Conf. Data Engineering (ICDE)*, 2006, p. 25.

[16] M. Bun and T. Steinke, "Concentrated differential privacy: Simplifications, extensions, and lower bounds," in *Proc. Theory of Cryptography Conf. (TCC)*, 2016.

[17] N. Moustafa and J. Slay, "UNSW-NB15: A comprehensive data set for network intrusion detection systems (UNSW-NB15 network data set)," in *Proc. Military Communications and Information Systems Conf. (MilCIS)*, 2015, pp. 1–6.

[18] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, "Toward generating a new intrusion detection dataset and intrusion traffic characterization," in *Proc. 4th Int. Conf. Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.

[19] Z. Long *et al.*, "A transformer-based network intrusion detection approach for cloud security," *Journal of Cloud Computing*, 2024.

[20] Y. Yang *et al.*, "BERT-based network for intrusion detection system," *EURASIP Journal on Information Security*, 2025.

[21] M. Sajid, K. R. Malik, A. Almogren, T. S. Malik, A. H. Khan, J. Tanveer, and A. U. Rehman, "Enhancing intrusion detection: a hybrid machine and deep learning approach," *Journal of Cloud Computing*, vol. 13, no. 1, 2024.

[22] Y. Gorishniy, I. Rubachev, V. Khrulkov, and A. Babenko, "Revisiting deep learning models for tabular data," in *Advances in Neural Information Processing Systems (NeurIPS)*, 2021.

[23] S. K. Bhowmick *et al.*, "A machine learning framework for enhancing threat detection in core banking systems," *Scientific Reports*, 2026.

[24] P. R. Mulea *et al.*, "AI-augmented proactive cyber-detection and mitigation of cybersecurity threats in the banking sector," in *Proc. Int. Conf. Cyber Warfare and Security (ICCWS)*, 2026.

[25] B. McMahan, E. Moore, D. Ramage, S. Hampson, and B. A. y. Arcas, "Communication-efficient learning of deep networks from decentralized data," in *Proc. 20th Int. Conf. Artificial Intelligence and Statistics (AISTATS)*, 2017, pp. 1273–1282.

[26] P. Ruzafa-Alcazar *et al.*, "Intrusion detection based on privacy-preserving federated learning for the industrial IoT," *IEEE Transactions on Industrial Informatics*, 2023.

[27] C. Gutti *et al.*, "Federated learning for distributed IoT security: A privacy-preserving approach to intrusion detection," *IEEE Access*, 2025.

[28] A. Vyas *et al.*, "Privacy-preserving federated learning for intrusion detection in IoT environments: A survey," *IEEE Access*, 2024.

[29] M. Abadi, A. Chu, I. Goodfellow, H. B. McMahan, I. Mironov, K. Talwar, and L. Zhang, "Deep learning with differential privacy," in *Proc. ACM SIGSAC Conf. Computer and Communications Security (CCS)*, 2016, pp. 308–318.

[30] G. Engelen, V. Rimmer, and W. Joosen, "Troubleshooting an intrusion detection dataset: the CICIDS2017 case study," in *Proc. IEEE Security and Privacy Workshops (SPW)*, 2021.

[31] M. Catillo *et al.*, "Transferability of machine learning models learned from public intrusion detection datasets: the CICIDS2017 case study," *Software Quality Journal*, 2022.

[32] D. Arp, E. Quiring, F. Pendlebury, A. Warnecke, F. Pierazzi, C. Wressnegger, L. Cavallaro, and K. Rieck, "Dos and don'ts of machine learning in computer security," in *Proc. 31st USENIX Security Symposium*, 2022, pp. 3971–3988.

[33] P. Barnard *et al.*, "Robust network intrusion detection through explainable artificial intelligence (XAI)," *IEEE Networking Letters*, 2022.

[34] L. Sweeney, "k-anonymity: A model for protecting privacy," *Int. J. Uncertainty, Fuzziness and Knowledge-Based Systems*, vol. 10, no. 5, pp. 557–570, 2002.

[35] S. Hochreiter and J. Schmidhuber, "Long short-term memory," *Neural Computation*, vol. 9, no. 8, pp. 1735–1780, 1997.

[36] A. Vaswani, N. Shazeer, N. Parmar, J. Uszkoreit, L. Jones, A. N. Gomez, Ł. Kaiser, and I. Polosukhin, "Attention is all you need," in *Advances in Neural Information Processing Systems (NeurIPS)*, 2017, pp. 5998–6008.

[37] N. V. Chawla, K. W. Bowyer, L. O. Hall, and W. P. Kegelmeyer, "SMOTE: Synthetic minority over-sampling technique," *Journal of Artificial Intelligence Research*, vol. 16, pp. 321–357, 2002.

[38] L. Yang, A. Moubayed, and A. Shami, "MTH-IDS: A multitiered hybrid intrusion detection system for Internet of vehicles," *IEEE Internet of Things Journal*, 2022.

[39] F. T. Liu, K. M. Ting, and Z.-H. Zhou, "Isolation forest," in *Proc. 8th IEEE Int. Conf. Data Mining (ICDM)*, 2008, pp. 413–422.

[40] L. Breiman, "Random forests," *Machine Learning*, vol. 45, no. 1, pp. 5–32, 2001.